

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

Security Awareness and Training Policy (AT)

Security Awareness and Training Policy (AT)

Table of Contents

1.0. Document Purpose 2

2.0. Scope 2

3.0. Policy Conflict 2

4.0. Roles and Responsibilities 2

5.0. Management Commitment 3

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 4

9.0. Document Details 7

10.0. Review 8

11.0. Records Management 8

12.0. Public Records Exceptions 8

13.0. Definitions 8

14.0. Abbreviations 10

1.0. Document Purpose

The purpose of this document is to define the State of Maine policy and procedures that are in place to ensure training and awareness of cybersecurity practices are established and adequate for State of Maine staff and information assets (see Definitions). This part of the security program is focused on protecting the confidentiality (see Definitions), integrity (see Definitions), and availability (see Definitions) of State information assets. This document corresponds to the Security Awareness and Training Policy (AT) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1].

2.0. Scope

2.1. This policy applies to all State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch managed services.

3.0. Policy Conflict

If this policy conflicts with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

4.1. Agency Management:

4.1.1. Enforces this policy as outlined in section 7.0, Compliance.

4.1.2. Establishes and conducts privacy training to meet regulatory requirements and business needs.

4.1.3. Ensures that agency personnel have access to and receive the enterprise security awareness training (see Definitions) at required intervals. This includes:

4.1.3.1. Ensuring that agency personnel with access to State email receive the enterprise security awareness training delivered by the Office of Information Technology.

4.1.3.2. Ensuring that agency personnel without access to State email are provided with alternative access to the enterprise security awareness training.

4.1.4. Determines agency personnel security awareness training requirements that extend beyond the enterprise security awareness training.

4.1.5. Ensures agency personnel are aware of all applicable penalties for noncompliance. (See section 7.0).

[1] https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

4.1.6. Maintains agency personnel security awareness training records, in accordance with State of Maine and any additional statutory records retention requirements that apply.

4.1.7. Develops and implements agency-level policy and procedures to meet Federal statutory requirements pertinent to security awareness and training.

4.2. OIT Information Security Office:

4.2.1. Owns, executes, and shares responsibility for enforcement of this policy.

4.2.2. Determines the training modules and content to be included in enterprise security awareness training.

4.2.2.1. Delivers enterprise security awareness training to agency personnel who have a State email account.

4.2.2.2. Makes records of training delivered available to authorized agency personnel.

4.2.2.3. Consults with agencies to help determine the training delivery mechanisms and options to meet agency security awareness training requirements that extend beyond the enterprise security awareness training.

4.2.2.4. Conducts agency phishing (see Definitions) exercises.

4.2.3. Security Governance and Training Officer reviews and reports on security training metrics (see 8.5 for details on metrics).

5.0. Management Commitment

The State of Maine is committed to following this policy and the procedures that support it.

6.0. Coordination Among Agency Entities

6.1. OIT coordinates with agencies to deliver enterprise security awareness training in accordance with Executive Order 25 FY 20/21.[2]

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in removal of the individual's ability to access, and use, State of Maine data and systems. Employers of contractors will be notified of any violations.

[2] https://www.maine.gov/governor/mills/sites/maine.gov.governor.mills/files/inline-files/EO%2082%2025.pdf

7.3. Personnel are also subject to any applicable penalties for statutory requirements compliance violations. Depending on the requirement, and the nature of the violation, penalties could include fines and/or criminal charges.

7.3.1. Two distinct compliance scenarios:

7.3.1.1. Failure to complete the mandated training within the mandated timeframe; and

7.3.1.2. Repeatedly failing the simulated phishing tests.

7.4. Failure to complete the mandated training within the mandated timeframe results in progressive discipline. This will be decided through collaboration between Agency Management and the Department of Administrative and Financial Services (DAFS) Bureau of Human Resources.

7.5. Repeatedly failing the simulated phishing tests results in a combination of additional tiered security training and progressive discipline. The details of the additional tiered security training will be decided through collaboration between Agency Management and the OIT Information Security Office. The OIT Information Security Office can provide Agency Management with a suggested sample of additional tiered security training. But it is the responsibility of Agency Management to track and manage the details of the additional tiered security training. Any progressive discipline due to repeated failing of the simulated phishing tests will be decided through collaboration between Agency Management and the DAFS Bureau of Human Resources.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine.

8.1. Security Awareness Training (AT-2, (2), (3)**)**

8.1.1. Agencies ensure their personnel receive enterprise security awareness training, which includes but is not limited to, content on recognizing and reporting potential indicators of insider threat, social engineering, and mining (see Definitions):

8.1.1.1. As part of initial training for new users (onboarding);

8.1.1.2. When required by information system changes; and

8.1.1.3. At least annually thereafter.

8.1.2. State of Maine employee orientation informs new personnel of security awareness training requirements. New employees are informed about their duties regarding confidentiality, privacy, and conflict of interest, as documented in the Bureau of Human Resources Employee Handbook.[3]

[3] https://www.maine.gov/bhr/sites/maine.gov.bhr/files/inline-files/EmployeeHandbook.pdf

8.1.3. The OIT Information Security Office delivers enterprise security awareness training that includes content on recognizing and reporting potential indicators of insider threat to agency users with email addresses by:

8.1.3.1. Querying the Active Directory (AD) each month to identify new agency users so that agencies do not need to inform the OIT Information Security Office of new hires.

8.1.3.2. Automatically pushing out enterprise security awareness training to new agency personnel (new AD users).

8.1.3.3. Automatically pushing out enterprise security awareness training to agency personnel annually and thereafter.

8.1.3.4. Delivering enterprise security awareness training to agency personnel at other intervals, upon agency requests (such as when required by information system changes).

8.1.3.5. Maintaining a list of agency personnel who have not received enterprise security awareness training.

8.1.3.6. Redelivering training at set intervals, as necessary.

8.1.4. Agencies are responsible for the delivery of enterprise security awareness training for agency personnel who do not have a State email address.

8.1.5. For each Executive Branch agency, the OIT Information Security Office conducts quarterly phishing exercises that simulate cyberattacks. The schedule is randomized, so agency exercises can occur at any time during a particular quarter.

8.1.6. Recognizing and reporting suspicious communications and anomalous behavior in information systems (AT-2(4)).

8.1.6.1. The OIT Information Security Office provides security awareness activities and training through:

8.1.6.1.1. Monthly phishing exercises;

8.1.6.1.2. Cybersecurity Awareness Month (October) activities; and

8.1.6.1.3. Biannual training in April and October.

8.1.7. Advanced Persistent Threat (APT)–(AT-2(5))

8.1.7.1. For State of Maine employees, the Security Operations Center (SOC)+ Training provides Security Alert email notifications as needed to educate on threats and actions required to address those threats.

8.1.7.2. State personnel responsible for continuous monitoring in the SOC receive training through:

8.1.7.2.1. Anomali ThreatStream offers two premium high-fidelity real-time intel streams from Mandiant, which provide comprehensive tracking of APT activities (campaigns, known IOCs, etc.)

8.1.7.2.2. A daily bulletin/brief produced from the Threat Intelligence Program.

8.1.7.2.3. A quarterly Threat Intelligence report delivered to the Chief Information Security Officer (CISO) and/or the Deputy Chief Information Security Officer (DCISO) that provides information for the Homeland Security meeting.

8.2. Role-Based Security Training (AT-3)

8.2.1. Agencies must determine the appropriate content of security training based on the assigned roles and responsibilities of personnel, regulatory requirements, and the information systems to which personnel have authorized access.

8.2.2. Agencies ensure that personnel with assigned security roles and responsibilities receive role-based security training:

8.2.2.1. Before authorizing access to information, an information system, or performing assigned duties that require access to Personally Identifiable Information (PII) (see Definitions) or other sensitive information;

8.2.2.2. When required by information system changes; and

8.2.2.3. At least annually thereafter.

8.2.3. If agency security awareness training requirements extend beyond enterprise security awareness training, then the agency consults with the OIT Information Security Office to help determine the training delivery mechanism and options.

8.2.4. The OIT Information Security Office does not currently offer agencies role-based training, which is typically identified and fulfilled through individual professional development plans and through the training, testing, and exercise components of agency contingency or incident response plans.

8.2.5. OIT internally completes role-based security training as described in 8.3.4 and in Contingency Plan Training, Testing and Exercise Procedures (IR-2, CP-3, IR-3, and CP-4)[4] (intranet only).

[4] http://inet.state.me.us/oit/policies/documents/TrainingTestingExercises.pdf

Personally Identifiable Information (PII) Training (AT-3(5)

8.2.6. Agencies are responsible for providing privacy training to all individuals who access PII.

8.2.7. MaineIT provides annual training in KnowBe4 for the following:

8.2.7.1. Federal Tax Information (FTI) to MaineIT Personnel

8.2.7.2. Criminal Justice Information Services (CJIS) to MaineIT Personnel

8.2.7.3. Social Security Administration (SSA) to Department of Health and Human Services (DHHS) to MaineIT Personnel

8.2.7.4. Health Insurance Portability and Accountability Act (HIPAA) to MaineIT Personnel

8.3. Security Training Records (AT-4)

8.3.1. Agencies must retain individual training records including privacy based training in accordance with the State Archives Records General Retention Schedule,[5] and any other applicable regulatory requirements for records retention.

8.3.2. The OIT Information Security Office monitors and maintains security awareness training records for any training it delivers.

8.3.3. At the completion of the training, personnel are instructed to keep their certificates of completion.

8.3.4. The training portal keeps a historical record of agency personnel who complete the training.

8.3.5. The OIT Information Security Office makes agency training completion reports available to designated agency personnel, upon request.

8.4. Training Feedback (AT-6)

8.4.1. The Security Governance and Training Officer reports training and phishing exercise statistics:

8.4.1.1. To CIO via biweekly report.

8.4.1.2. To Information Security Governance (ISG) Committee via monthly presentation or as needed.

8.4.2. Executive leadership has access to Splunk to review training and phishing results on an ad-hoc basis.

8.4.3. Staff can request training status/updates for phishing through inquiry via Security.Training@maine.gov.[6]

9.0. Document Details

[5] https://www.maine.gov/sos/arc/records/state/generalschedules.html
[6] Security.Training@maine.gov

9.1. Initial Issue Date: March 11, 2014

9.2. Latest Revision Date: September 5, 2025

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[7]

9.6. Waiver Process: Waiver Policy[8]

9.7. Distribution: Internet[9]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after withdrawal or replacement and then destroyed in accordance with guidance[10] provided by Maine State Archives. Retention of these documents will be subject to any future State archives general schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[11] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as to security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Advanced Persistent Threat: A sophisticated and sustained cyberattack where an attacker establishes an undetected presence in a network to steal sensitive data over an extended period.

13.2. Availability: Timely and reliable access to and use of information assets.

---

[7] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[9] https://www.maine.gov/oit/policies-standards
[10] https://www.maine.gov/sos/sites/maine.gov.sos/files/content/assets/GS1Administrative.pdf
[11] https://legislature.maine.gov/statutes/1/title1sec402.html

13.3. Confidentiality: The state of being kept private or secret, including preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.

13.4. Enterprise Security Awareness Training: Training that provides a basic understanding of the need for information security and user actions to maintain security and privacy and to respond to suspected security and privacy incidents. The content also addresses awareness of the need for operations security and privacy related to the organization's information security program.

13.5. Information Asset: Used interchangeably with Information System. A discrete, identifiable piece of information technology, including hardware, software, firmware, systems, services, and related technology assets used to execute work on behalf of OIT or another State agency. (National Institute of Standards and Technology (NIST) Special Publication (SP) 800-30).

13.6. Insider Threat: The potential for individuals (e.g., employees, contractors, former employees) to use insider knowledge of sensitive agency information (e.g., security practices, systems that hold sensitive data) to perform malicious actions, including unauthorized access or disclosure of Personally Identifiable Information or other sensitive information.

13.7. Integrity: The accuracy and consistency (validity) of data over its lifecycle. Guarding the integrity of information assets against improper modification or destruction includes ensuring information nonrepudiation and authenticity.

13.8. Mining: An attempt to gather information about the organization or individual that may be used to support future attacks.

13.9. Personally Identifiable Information (PII): Information that can be used to distinguish or trace the identity of an individual (for example, name, Social Security number, biometric records, etc.) alone, or when combined with other personal or identifying information that is linked or linkable to a specific individual (such as date and place of birth, mother's maiden name, etc.). It also includes personal information protected from disclosure under Federal or State privacy laws.[12]

13.10. Phishing: The practice of sending fraudulent communications that appear to come from a reliable source, usually through email, with the goal of stealing data, such as credit card or login information, or to install malware on the recipient's machine.

13.11. Sensitive Information: Information that has the potential to cause great harm to an individual, government agency, or program if abused, misused, or breached. Sensitive information may include PII, and is protected against unwarranted disclosure, and typically carries specific criminal and civil penalties for an individual convicted of unauthorized access, disclosure, or misuse (e.g., Federal tax, protected health, criminal justice, or Social Security information). Protection of

[12] https://csrc.nist.gov/glossary

sensitive information usually involves specific classification or legal precedents that provide special protection for legal and ethical reasons.

13.12. Social Engineering: An attempt to trick an individual into revealing information or taking an action that can be used to breach, compromise, or otherwise adversely impact a system. Social engineering includes phishing, pretexting, impersonation, baiting, quid pro quo, thread-jacking, social media exploitation, and tailgating.

14.0. Abbreviations

14.1.	APT:	Advanced Persistent Threat
14.2.	CIO:	Chief Information Officer
14.3.	CISO:	Chief Information Security officer
14.4.	CJIS:	Criminal Justice Information System
14.5.	DAFS:	Department of Administrative and Financial Services
14.6.	DCISO:	Deputy Chief Information Security Officer
14.7.	DHHS:	Department of Health and Human Services
14.8.	FOAA:	(Maine) Freedom of Access Act
14.9.	FTI:	Federal Tax Information
14.10.	HIPAA:	Health Insurance Portability and Accountability Act
14.11.	ISG:	Information Security Governance
14.12.	NIST:	National Institute of Standards and Technology
14.13.	OIT:	Office of Information Technology
14.14.	PII:	Personally Identifiable Information
14.15.	SSA:	Social Security Administration